

POL-SEC-002 - Confidential Information Handling Policy

Policy | IT

Document ID	POL-SEC-002	Seller ID	Organization-wide
Department	IT	Classification	INTERNAL
Owner	Admin	Created Date	2026-06-12
Version	2.2	Effective Date	2026-06-12
Related Scenario ID	SC-008	Document Type	Policy

1. Purpose

This policy defines how confidential and restricted information is created, stored, shared, transmitted and destroyed. It applies to information about sellers, customers, employees and the platform itself.

Its purpose is to make handling requirements explicit, so that a person handling a record does not have to infer the correct behaviour from its sensitivity.

2. Scope

Applies to all employees, contractors and service accounts handling any platform information.

Applies to all formats: documents, database records, tickets, transcripts, messages, code, configuration and diagnostic output.

3. Definitions

Term	Definition
Confidential information	Any record classified CONFIDENTIAL or RESTRICTED
Credential	Any secret used for authentication: password, key, token, secret
Diagnostic artefact	A script, log extract, query or output produced while investigating an issue
External sharing	Any transmission outside the company, including to a seller
At rest	Stored on any medium
In transit	Moving between systems or parties

4. General Rules

- R-1. Confidential information is accessed only where required for a work purpose, and only within the access model in the Data Access Policy.
- R-2. Confidential information is not copied to personal devices, personal accounts or unmanaged storage.
- R-3. Sharing externally requires authorisation from the record owner and must be limited to the minimum content necessary for the stated purpose.
- R-4. Where information is shared with a seller, it is limited to the seller's own account. A seller must never receive another seller's information, including in aggregate form where the aggregate would disclose it.

5. Credential Handling

R-5. Credentials are never embedded in source code, scripts, configuration files committed to version control, tickets, documentation or messages.

R-6. Credentials are resolved at runtime from the credential store. A person or process requiring a credential obtains it through the store, not from a stored value in another artefact.

R-7. **The distinction between staging and production credentials is not a distinction an attacker respects.** No diagnostic artefact containing any credential may be shared outside the company, regardless of the environment the credential belongs to.

R-8. Separate credentials must be issued for staging and production. A shared credential is prohibited.

R-9. All machine credentials are enrolled in automated rotation with a maximum age of 90 days.

R-10. Suspected credential exposure is treated as SEV-1 and escalated to IT immediately, without waiting to establish whether the credential is still valid.

Rule R-7 exists because of a specific failure. In April 2026 a support engineer shared a diagnostic script externally believing the credential it contained was a staging credential. The account used the same credential for staging and production, so it was in fact production-scoped and permitted write access to a seller's catalogue and price feed. The credential had not been rotated in 46 months.

6. Diagnostic Artefacts

R-11. Diagnostic tooling for seller integrations is provided centrally and resolves credentials from the store at runtime. Support engineers must not handle raw credential values.

R-12. Where an ad hoc script is unavoidable, it must not contain any connection detail, and it must be deleted after use rather than retained.

R-13. Diagnostic output containing seller data is classified at least CONFIDENTIAL and is stored only in approved locations. Extracts must not be left in shared directories or email.

R-14. Log extracts shared for troubleshooting must be reviewed to remove credentials, tokens and personal data before transmission, including transmission to a seller.

7. Storage and Transmission

R-15. Confidential information is stored in approved systems: the document store, the ticket system, the incident system or the approved data platform. It must not be stored in ad hoc locations.

R-16. Transmission of confidential information outside approved systems requires encryption and authorised recipients.

R-17. RESTRICTED information must not be reproduced in a lower-classified record. A reference may be made; the content must not.

A RESTRICTED incident record may be referenced from a CONFIDENTIAL ticket so that a reader knows it exists and who owns it. The RESTRICTED record's contents - credential detail, thresholds, risk determinations - must not be copied into the CONFIDENTIAL record, because that would defeat the classification.

R-18. Screenshots of confidential records are treated as confidential records and are subject to the same storage rules.

8. Retention and Destruction

R-19. Confidential information is retained only for the period defined in the Data Retention Policy, after which it is destroyed or de-identified.

R-20. Destruction is performed through an approved mechanism. Deleting a record from an application is not destruction where a backup retains it; the retention schedule governs.

R-21. Diagnostic artefacts are temporary by nature and must be deleted immediately after the investigation concludes.

9. Responsibilities

Role	Responsibility
All identities	Follow this policy; report suspected exposure immediately
Record owners	Correct classification; authorise external sharing
IT	Credential store, rotation, secret scanning, exposure response
Engineering	Central diagnostic tooling; secret scanning in the pipeline
Support	Use approved tooling; review extracts before sharing

R-22. Any identity who suspects a credential has been exposed must report it immediately. Reporting promptly is treated as correct behaviour regardless of how the exposure occurred.

The April 2026 exposure was reported and contained within 80 minutes of detection. The person who reported it was not penalised. The review concluded that the behaviour which created the exposure was a predictable consequence of inadequate tooling, and the corrective action belonged with the tooling.

10. Exceptions

E-1. Sharing confidential information with a seller is permitted under section 4 where limited to that seller's own account.

E-2. Sharing RESTRICTED information with a seller requires Platform Administrator authorisation and is limited to the operational facts the seller must act on. The seller is not given the classification framework or threshold detail behind a decision.

E-3. No exception may waive R-5, R-7, R-8 or R-9 (credential rules).

11. Escalation

Situation	Escalate to	Timeframe
Suspected credential exposure	IT, as SEV-1	Immediately
Suspected unauthorised access	IT, as SEV-1	Immediately
Request to share restricted information externally	Platform Administrator	1 working day
Unapproved storage of confidential information found	IT	1 working day
Secret detected in code	Engineering and IT	Immediately

12. Enforcement

Secret scanning runs in the CI pipeline and fails a build containing a credential. A full repository sweep is performed quarterly.

Credential rotation is automated and monitored. A credential exceeding its maximum age raises an alert to IT.

Access to confidential stores is governed by the Data Access Policy and reviewed quarterly.

Handling breaches are reviewed individually. Where a breach arose from inadequate tooling or unclear guidance, the corrective action addresses the tooling or the guidance rather than the individual.

13. Review History

Version	Date	Change	Owner
1.0	2022-07-19	Initial information handling policy	IT
2.0	2024-05-14	Classification-aligned handling requirements	IT
2.1	2026-04-22	Absolute prohibition on sharing diagnostic artefacts containing credentials	Admin
2.2	2026-06-12	Separate staging and production credentials; automated rotation	Admin

Next scheduled review: June 2027.